

SWAPTICS

Comprehensive Security & Production Readiness Audit

SECURITY SCORE	PRODUCTION READINESS	OVERALL RISK
7.0 / 10	7.0 / 10	MODERATE-HIGH

Branch: main | Commit: 17b8dd5 (Update security policies)

Repository state: main matches origin/main; audit output and temporary files are untracked

Assessment date: 22 August 2026

1. Executive Summary

The updated main branch materially improves the earlier audit posture. The legacy OTP and sequential delete-user Edge Function sources were removed, seller-badge insertion is now administrator-only, product-view insertion is tied to the signed-in user, and the administrator UI invokes the transactional database deletion routine. The production build succeeds and all 61 automated tests pass.

The branch is not yet ready for an unconditional production release. The replacement notification policy still allows any signed-in user to create trusted-looking system, badge, rating or message notifications for any other user. Deleting an Edge Function from Git does not undeploy it from Supabase, so the legacy OTP endpoint remains a conditional high-risk deployment concern until the cloud state is verified. Administrator-driven storage cleanup is also likely blocked by owner-only storage rules, leaving orphaned files.

This was a source-code and safe local verification audit. No live exploitation, production database access or destructive testing was performed. Dependency advisories remain unverified because an external advisory request was not authorized.

Verification summary

Check	Result	Evidence
Git state	PASS	main and origin/main at 17b8dd5
Production build	PASS	2,897 modules transformed
Tests	PASS	61/61 tests in two files
Lint	FAIL	4 errors and 88 warnings
Dependencies	NOT RUN	External advisory lookup not authorized

Finding distribution

Severity	Count	Release effect
Critical	0	None confirmed in source
High	2	Block release until fixed or deployment state disproves exposure
Medium	8	Resolve before or immediately after launch
Low	4	Hardening backlog

2. High-Risk Findings

1. Cross-user trusted-notification injection

HIGH

Impact: A normal user can send arbitrary system, badge, rating or message notifications to any other user, enabling impersonation, phishing-style prompts, spam and trust manipulation.

Evidence: Migration 20260819 replaces the fully open policy, but its WITH CHECK only requires a different non-null recipient and an allowed type. It does not bind the event to a chat, rating, badge award or server-side actor.

Recommended fix: Remove direct client insertion for privileged notification types. Create notifications through SECURITY DEFINER routines or server functions that validate the underlying business event. For messages, bind sender, chat membership and recipient in one transaction.

2. Legacy OTP function may still be deployed

HIGH

Impact: If the previously deployed unauthenticated OTP endpoint remains online, it can still be used for email-cost abuse and service-role account workflow probing.

Evidence: The source directory was deleted, but the repository maintenance notes require manual removal in the Supabase dashboard. Source deletion does not change already deployed cloud functions.

Recommended fix: Verify the deployed Functions inventory and undeploy send-otp. Revoke obsolete secrets, review invocation logs and add a deployment-state check to release procedures.

3. Medium-Risk Findings

3. Administrator setup likely uses an unsupported SDK method

MEDIUM

Impact: setup-admin calls auth.admin.getUserByEmail, which is absent from the installed Supabase client API.

Evidence: setup-admin calls auth.admin.getUserByEmail, which is absent from the installed Supabase client API. The admin-add workflow may fail at runtime. Use a supported server-side lookup and add a deployed integration test.

Recommended fix: Implement the stated control, verify it in staging, and add a regression test.

4. Admin deletion can leave orphaned storage

MEDIUM

Impact: The transactional RPC removes database/auth data, then the browser performs best-effort storage cleanup and ignores errors.

Evidence: The transactional RPC removes database/auth data, then the browser performs best-effort storage cleanup and ignores errors. Owner-only storage rules likely prevent an admin from deleting another user's folder. Move storage cleanup to a service-role server operation with retry/audit status.

Recommended fix: Implement the stated control, verify it in staging, and add a regression test.

5. Content Security Policy still permits unsafe inline scripts/styles

MEDIUM

Impact: The CSP retains 'unsafe-inline', weakening XSS containment.

Evidence: The CSP retains 'unsafe-inline', weakening XSS containment. Adopt nonces or hashes, eliminate inline execution and roll out a report-only policy first.

Recommended fix: Implement the stated control, verify it in staging, and add a regression test.

6. Product-view inflation remains possible

MEDIUM

Impact: viewer_id is now bound to the current user, but the same user can repeatedly insert views.

Evidence: viewer_id is now bound to the current user, but the same user can repeatedly insert views. Add a unique time-bucket constraint, server-side rate controls or derived analytics.

Recommended fix: Implement the stated control, verify it in staging, and add a regression test.

7. Security tests do not exercise actual security boundaries

MEDIUM

Impact: The 60 security tests largely duplicate helper logic and do not execute production RLS, Edge Functions or cross-account scenarios.

Evidence: The 60 security tests largely duplicate helper logic and do not execute production RLS, Edge Functions or cross-account scenarios. Add Supabase integration tests with owner, stranger and admin identities.

Recommended fix: Implement the stated control, verify it in staging, and add a regression test.

8. Lint release gate fails

MEDIUM

Impact: Four errors and 88 warnings remain, including empty-interface, prefer-const and CommonJS import violations.

Evidence: Four errors and 88 warnings remain, including empty-interface, prefer-const and CommonJS import violations. Fix all errors and maintain a controlled warning budget in CI.

Recommended fix: Implement the stated control, verify it in staging, and add a regression test.

9. Privileged administration lacks complete operational assurance

MEDIUM

Impact: Production migration state, function inventory, role changes and deletion behavior are not automatically attested.

Evidence: Production migration state, function inventory, role changes and deletion behavior are not automatically attested. Add immutable audit events, deployment checks and alerting for privileged actions.

Recommended fix: Implement the stated control, verify it in staging, and add a regression test.

10. Dependency vulnerability status is unknown

MEDIUM

Impact: No current package advisory scan was performed.

Evidence: No current package advisory scan was performed. Run the approved package-manager audit or CI scanner, triage direct and transitive dependencies, and record accepted risks.

Recommended fix: Implement the stated control, verify it in staging, and add a regression test.

4. Lower-Risk Engineering, UX, Accessibility and SEO Gaps

11. Administrative list scalability

LOW

Impact: Broad selects and limited pagination can increase latency and memory use as users/products grow. Select only required fields and paginate server-side.

Evidence: Broad selects and limited pagination can increase latency and memory use as users/products grow. Select only required fields and paginate server-side.

Recommended fix: Add the recommended validation to the release checklist and automated coverage where practical.

12. Client-side upload validation is not a security boundary

LOW

Impact: Size and type checks improve UX but can be bypassed. Enforce MIME, extension, size and image decoding in a trusted server/storage workflow.

Evidence: Size and type checks improve UX but can be bypassed. Enforce MIME, extension, size and image decoding in a trusted server/storage workflow.

Recommended fix: Add the recommended validation to the release checklist and automated coverage where practical.

13. SPA SEO coverage is limited

LOW

Impact: Client-rendered routes may have inconsistent canonical, structured-data and social metadata. Add route-specific metadata and prerender or SSR for important public pages.

Evidence: Client-rendered routes may have inconsistent canonical, structured-data and social metadata. Add route-specific metadata and prerender or SSR for important public pages.

Recommended fix: Add the recommended validation to the release checklist and automated coverage where practical.

14. Accessibility needs automated and manual regression testing

LOW

Impact: Add keyboard-only, screen-reader, focus-order, contrast and form-error checks to CI and release QA, especially for dialogs and admin workflows.

Evidence: Add keyboard-only, screen-reader, focus-order, contrast and form-error checks to CI and release QA, especially for dialogs and admin workflows.

Recommended fix: Add the recommended validation to the release checklist and automated coverage where practical.

5. Confirmed Improvements

- Single Supabase authentication model remains aligned with `auth.uid()` and RLS.
- Seller-badge insertion policy is explicitly replaced with administrator-only insertion.
- Administrator deletion now calls the transactional `admin_delete_user_cascade` RPC.
- Legacy `send-otp` and `delete-user` function sources were removed from the repository.
- Product-view writes now require `viewer_id` to be null or the authenticated user.
- Native `confirm/alert/prompt` usage is restricted by lint policy.
- Production build passes and route-level code splitting is present.
- All 61 local automated tests pass.

6. Access Needed to Remediate and Verify

Access	Minimum level	Purpose
Repository + CI	Remediation branch / pipeline logs	Code, tests, lint and release gates
Supabase database	Migration deployer; read-only <code>pg_policies</code> review	Apply and verify RLS/RPC changes
Supabase Functions	Function inventory, deploy/undeploy and logs	Remove legacy OTP; validate setup-admin
Supabase Storage	Policy editor plus service-role cleanup workflow	Prevent and clean orphaned user files
Supabase Auth	Staging admin plus two test users	Cross-user and privileged flow testing
Vercel/DNS	Deployment config and security headers	CSP, domains, secrets and rollback
Monitoring	Read logs; create alerts	Detect abuse and privileged failures

7. Prioritized Action Plan

P0 - Before release

- Replace direct notification insertion with validated server/database routines
- Confirm and undeploy the legacy send-otp function
- Inspect effective production pg_policies and function inventory
- Fix the four lint errors

P1 - Privileged workflows

- Repair and integration-test setup-admin email lookup
- Move cross-user storage cleanup to a service-role backend with retry tracking
- Add immutable logs for admin grants and deletion
- Run cross-account staging tests

P2 - Defense in depth

- Remove unsafe-inline CSP using nonces/hashes
- Add product-view deduplication/rate controls
- Enforce uploads on a trusted boundary
- Run an approved dependency scan

P3 - Quality and discoverability

- Replace copied security tests with production and RLS integration tests
- Paginate administrative datasets
- Complete accessibility QA
- Add route-level SEO metadata/prerendering

Release gate

- No normal user can create privileged notifications for another user
- Production function inventory contains no unused OTP endpoint
- Admin grant, deletion and storage cleanup pass end-to-end staging tests
- Build, lint and tests all pass in CI
- Effective production policies match the reviewed migration intent
- Dependency advisories are reviewed and documented

8. Scope and Method

Reviewed areas included application routes and UI flows, authentication and administrator logic, Supabase migrations and RLS, Edge Functions, storage interactions, validation utilities, build/lint/test configuration, performance indicators, accessibility and SEO surfaces, and deployment documentation. Evidence was derived from commit 17b8dd5 and safe local build/test/lint execution.

Limitations

- No production credentials, database policy export or deployed-function inventory was available.
- No live penetration test, denial-of-service simulation, email abuse test or destructive account deletion was performed.
- No external dependency advisory service was contacted.
- Runtime conclusions about cloud state are conditional until staging/production verification is completed.

Conclusion

The current branch is meaningfully safer and demonstrates solid remediation progress. Its central remaining source-level weakness is the notification authorization model; its central operational risk is unverified cloud deployment state. Resolve those release blockers, repair privileged storage/setup flows, and establish real RLS integration testing before treating Swaptics as fully production-ready.

End of report